

Cybersecurity Risk Assessment Report

Stirling Bank (Fictional Commercial Bank)

Business Confidential

Assessment of cybersecurity, governance and AI risk posture across hybrid banking infrastructure

Aligned to: NIST CSF, ISO 27001, GDPR & NIST AI RMF

Prepared for: Executive Leadership Team

Prepared by: Maahir Shah

Date: 6th May 2026

Version 1.0

Table of Contents

Confidentiality Statement.....	2
Disclaimer.....	2
Contact Information.....	2
Scope & Objectives.....	3
Finding Severity Ratings	3
Testing Methodology.....	4
System Overview	4
Key Risk Themes.....	5
Risk Findings	6
Finding R-01: Identity & Access Management Risk (High Risk)	6
Finding R-02: Unencrypted Log Information (High Risk)	7
Finding R-03: Reused Employee Credentials (High Risk)	8
Finding R-04: Internal AI Prompt Injection (High Risk)	9
Finding R-05: Insufficient Password Policy (High Risk)	10
Finding R-06: Outdated Legacy Systems (High Risk)	11
Finding R-07: Lack of Behavioural Records (Medium Risk)	12
Finding R-08: Lack of Data Minimisation (Medium Risk).....	13
Finding R-09: Manual Fraud Detection (Medium Risk)	14
Finding R-10: Mobile App AI Bias (Medium Risk)	15
Finding R-11: AI Over-Dependence & Insufficient Explainability (Medium Risk)	16
Finding R-12: Inconsistent Security Logging (Low Risk)	17
Finding R-13: Inconsistent Security Logging (Low Risk)	18
AI Risk & Ethics.....	19
Conclusion.....	19

Confidentiality Statement

This document is the exclusive property of Stirling Bank and Maahir Shah (referred to as 'the GRC team' within this report). This document contains proprietary and confidential information. Duplication, redistribution, or use, in whole or in part, in any form, requires consent of both Stirling Bank and the GRC team.

Disclaimer

A GRC (Governance; Risk; Compliance) assessment is considered a snapshot in time. The findings and recommendations reflect the information gathered during the assessment and not any changes or modifications made outside of that period.

Time-limited engagements do not allow for a full evaluation of all GRC compliance, or lack thereof. The GRC team prioritised the assessment to identify the most significant GRC failings Stirling Bank must remediate. The GRC team recommends conducting similar assessments periodically, through automation in accordance to GRC guidelines, to ensure they are consistently compliant with regulation and cybersecurity frameworks.

Contact Information

Name	Title	Contact Information
Stirling Bank	Client	Email: stirling@bank.com
Maahir Shah	GRC Professional	Email: shlkrms1@gmail.com

Executive Summary

Stirling Bank is a high-street bank offering standard financial services, such as loaning and mobile banking.

This Governance, Risk and Compliance (GRC) assessment uncovered Stirling Bank's security posture. It identified the hybrid banking infrastructure used, systems, GRC incompliance and security flaws.

The GRC team identified a number of major risks within the company. These risks included critical weaknesses in identity management Finding R 01 , cloud data protection Finding R 02) and AI governance Findings R 04; R 11; R 10 . These risks, paired with failure to comply with secure GRC frameworks, exposes the bank to regulatory, financial, operational and reputational risks.

Scope & Objectives

The GRC team analysed the following systems permitted by Stirling Bank:

- AWS systems
- Internal Active Directory staff network
- Core banking system
- Fraud detection system
- AI systems
- Organisational system

These systems were assessed in line with the following GRC frameworks:

- NIST Cybersecurity Framework NIST CSF
- NIST 800 39
- ISO 27001
- GDPR

Finding Severity Ratings

The Audit Spreadsheet provided provides the following severity rating scores listed below.

Impact

Impact of a risk is rated on a scale of 1 to 5, with 1 indicating no risk and 5 indicating severe risk.

Risk impact assesses the degree of realised or un-realised damage by the risk to Stirling Bank.

Risk Level

Risk level is assigned out of three levels: Low; Medium; High.

Risk level indicates the likelihood of that risk posing significant damage to Stirling Bank.

Testing Methodology

The team analysed Stirling Bank's architecture, including its AWS cloud environment, internal Active Directory network for staff, its legacy core banking system and AI systems. These systems were individually assessed to identify potential risks and lack of compliance.

Risk modelling was performed for each system as part of their analyses. Factors such as external attackers, internal threats, misconfigurations and system abuse were taken into consideration. Attack scenarios were mapped for each risk to indicate the path of exploitation an adversary may take against Stirling Bank.

The systems were assessed in accordance to the GRC regulatory frameworks stated in the Scope & Objectives section. The guidelines of each of these frameworks were considered and the risks of Stirling Bank's lack of compliance with these frameworks were identified and recorded within the Audit Spreadsheet.

Each risk was recorded by linking the systems involved, vulnerabilities and risk scenarios to potential business and regulatory impacts. Each risk was assessed based on impact and likelihood to indicate overall severity.

System Overview

Stirling Bank utilised a hybrid banking infrastructure, composed of AWS systems and its legacy core banking system. AWS systems were in place to store customer data, financial transaction logs and the mobile banking application used by customers. The legacy core banking system stored customer account information, processed transactions and handled customer balances.

Stirling Bank utilised an Active Directory internal network for its staff members. This was in place for internal identity and resource management within the bank itself.

Stirling Bank also utilised AI systems. An internal AI chatbot assistant helped employees query sensitive customer data for operations such as customer service.

A fraud detection system was also in effect. Manual fraud investigation by employees was in place in an effort to detect anomalous or potentially fraudulent activity.

Key Risk Themes

This GRC report explores the following key risk themes:

Risk	Explanation
Identity & Access Management IAM	IAM is concerned with verifying the identity of an individual, along with allocating the appropriate privileges to the correct users.
Encryption	Encryption is concerned with securing plaintext, sensitive data through encryption algorithms. Encryption aims to prevent unauthorised individuals from reading sensitive data.
Credential Policy	A credential policy dictates how credentials should be handled within an organisation. It includes enforcing a degree of password complexity and educating employees on the importance of credential safety.
Responsible AI Usage	Responsible AI usage is essential to preventing AI systems from becoming a security weak-point in an organisation's infrastructure. It is also key to ensuring accountability, explainability and traceability of AI actions.
Infrastructure	An organisation relies on its infrastructure to remain operational. Legacy infrastructure tends to be difficult to replace. Modern updates pose a risk to corrupting functionality. Legacy systems may not receive security updates from vendors if they go out-of-service, posing a severe security threat. Upgrading legacy systems also poses the risk of operational downtime, negatively impacting an organisation's reputation and function.

Fraudulent Activity	Potential fraud involves anomalous transactions and banking activity, which could potentially hint at malpractice. It is important to flag and monitor potential fraudulent activity to protect customers' money and comply with lawful practice.
Responsible Data Handling	An organisation storing customer data is responsible for its secure processing and handling. In accordance to the GDPR regulations, data must be handled in a way that protects the privacy of those related to the data.

Risk Findings

Finding R-01: Identity & Access Management Risk (High Risk)

Description	Developers for the mobile banking application retained administrative access beyond what was required for their role. This violates the principle of least privilege, thus increasing the organisation's risk of insider attacks.
Risk Scenario	A resentful developer could exploit their retained administrative privileges to steal sensitive client financial data without detection.
Impact Level	5
Business Impact	Such an insider attack could lead to significant system compromise, reputational damage and loss of customer trust. This may result in penalty fines for Stirling Bank, indicating financial implications.
Framework Compliance	The NIST Cybersecurity Framework and ISO 27001 Framework focus on identity and access control management. Follow NIST CSF guidelines, particularly regarding the principle of least privilege and regular privilege audits.
Remediation	Reassess privileges organisation-wide regularly. Assign privileges based on role, not person.

Finding R-02: Unencrypted Log Information (High Risk)

Description	Sensitive customer data, including account numbers, were stored within AWS cloud storage without encryption. This increases the risk of exposure to an adversary in the event
	of unauthorised access. Sufficient data protection measures were not implemented.
Risk Scenario	An attacker successfully phishes the credentials of an employee of Stirling Bank to access AWS storage services. From here, the attacker can retrieve and read log files containing the unencrypted customer data.
Impact Level	5
Business Impact	This can result in significant reputational damage, regulatory fines and a potential lawsuit.
Framework Compliance	The NIST Cybersecurity Framework and ISO 27001 Framework focus on protecting data. This risk reflects non-compliance with data protection measures, such as encryption.
Remediation	Encrypt sensitive data and information stored in AWS, including log data. Sanitise logs to obfuscate or remove sensitive customer information and minimise unnecessary logging where possible.

Finding R-03: Reused Employee Credentials (High Risk)

Description	Employees of Stirling Bank reuse their credentials across multiple applications and internal systems integrated with the Active Directory network. This increases the likelihood of password-based attacks succeeding across the system.
Risk Scenario	An attacker successfully phishes the credentials of an employee of Stirling Bank. From here, the password can spray passwords across the Active Directory network, authenticate to multiple internal systems and move laterally.
Impact Level	5
Business Impact	This can result in significant system compromise, operational disruption and data breaches. As a result, Stirling Bank may face regulatory fines and loss of customer trust.
Framework Compliance	The NIST Cybersecurity Framework and ISO 27001 Framework focus on a strong credential policy. This risk signals an insufficient credential policy and thus non-compliance with these frameworks.
Remediation	Introduce MFA where possible as an extra authentication layer to deter attackers in the event of credential compromise.

Finding R-04: Internal AI Prompt Injection (High Risk)

Description	Stirling Bank employs an internal AI chatbot to support employees' queries for sensitive customer and business data. The AI chatbot lacks sufficient against prompt injection attacks, leading to potential AI behaviour manipulation and bypass of in-place restrictions.
Risk Scenario	An employee may purposefully or accidentally directly inject prompt to override system restrictions and perform unintended actions within the bank's system.
Impact Level	5
Business Impact	Data leakages are possible through prompt injection, resulting in non-compliance with the GDPR framework and reputational damage. Legal consequences are possible due to insufficient AI security measures.
Framework Compliance	This risk highlights a gap in AI governance and safety as outlined in the NIST AI Risk Management Framework. Data leakages due to AI manipulation overlaps with GDPR non-compliance, which emphasises the importance of data protection for customer privacy.
Remediation	Implement prompt filtering by training the AI chatbot to recognise malicious inputs. Audit AI chatbot access controls within the bank's internal systems to limit malicious system change attempts.

Finding R-05: Insufficient Password Policy (High Risk)

Description	Building on from R 03, credentials in the Active Directory environment are not enforced to have a sufficient password complexity. This increases the success rate of password-based attacks within the network.
Risk Scenario	An adversary can attempt brute-force techniques with greater success, allowing for privilege escalation and/or lateral movement between user accounts.
Impact Level	4
Business Impact	An insufficient policy for password complexity can lead to widespread system compromise and legal implications, such as regulatory fining.
Framework Compliance	This risk reflects a deficiency in the password policy of Stirling Bank and account protection measures as defined in
	the ISO 27001 and NIST CSF frameworks.
Remediation	Implement MFA as an extra layer of authentication across critical systems where possible. Enforce a stronger password policy and an account lockout system after a number of failed attempts.

Finding R-06: Outdated Legacy Systems (High Risk)

Description	The legacy core banking systems used by Stirling Bank no longer receive security patches by vendors. Vulnerabilities remain unaddressed and prone to exploitation.
Risk Scenario	An adversary can exploit known vulnerabilities in legacy banking systems and gain unauthorised access or cause system downtime. Legacy systems tend to be inter-dependent and malicious access could seep through to other systems allowing for potential fraudulent transactions and extraction of sensitive data.
Impact Level	4
Business Impact	This could lead to operational downtime if the attacker causes system damage or runs a Denial of Service attack which the legacy systems aren't designed to withstand. Fraudulent transactions could lead to financial loss. Data extraction can lead to reputational damage for the bank.
Framework Compliance	This risk reflects non-compliance with ISO 27001 and NIST CSF guidelines relating to system maintenance and vulnerability management due to insufficient patching.
Remediation	Gradually replace legacy core banking systems with modern, more secure systems. Where possible, isolate legacy systems to reduce risk of lateral movement between bank infrastructure. Consider implementing an Intrusion Detection System (IDS) to monitor for potential security breaches in real-time.

Finding R-07: Lack of Behavioural Records (Medium Risk)

Description	Stirling Bank maintains insufficient behavioural baseline data on ordinary user activity. This makes it difficult for fraud detection mechanisms to detect anomalous activity which could be potentially fraudulent.
Risk Scenario	Adversaries can carry out fraudulent activity without being flagged by fraud detection mechanisms.

Impact Level	4
Business Impact	This could lead to potential financial losses due to fraud. Stirling Bank may also face reputational damage and potential legal consequences for failing to detect fraudulent activity.
Framework Compliance	This risk reflects non-compliance with NIST CSF guidelines due to a lack of anomaly detection.
Remediation	Collect more detailed behavioural analytics data to help inform fraud detection mechanisms and recognise suspicious banking activity. Implement a stronger detection system for anomalous behaviour.

Finding R-08: Lack of Data Minimisation (Medium Risk)

Description	Stirling Bank stores excessive customer data within AWS beyond what is operationally needed. This includes sensitive information such as account numbers and customer identifiers. This increases the risk of unnecessary exposure of data in the event of a data breach.
Risk Scenario	If AWS storage is compromised, the attacker can gain access to information, like customer identification, that should not have been stored. This increases the severity of the data breach.
Impact Level	4
Business Impact	This can lead to regulatory fines due to exposure of sensitive data. It can also result in reputational damage and loss of customer trust in the bank's ability to defend their data.
Framework Compliance	This risk reflects non-compliance with GDPR guidelines of data minimisation and maintaining customer privacy. It also reflects non-compliance with ISO 27001 due to insecure data handling practices.
Remediation	Implement policies for data minimisation and implement greater data security measures (such as auto-deletion rules). Regularly audit data security.

Finding R-09: Manual Fraud Detection (Medium Risk)

Description	Stirling Bank relies on manual investigation of fraud and potential fraudulent activity. The lack of automation for fraud
	detection results in delays and inconsistencies, limiting response effectiveness.
Risk Scenario	Fraudulent transactions may occur but manual investigation means forensics are susceptible to human error and misjudgement. Correcting human errors and misjudgement can result in a delayed response, allowing the attacker to perform more fraudulent activity.
Impact Level	4
Business Impact	This can lead to significant financial losses if the adversary manages to execute multiple fraudulent transactions. It can also result in reputational damage as customers lose trust in the bank to safeguard their savings efficiently.
Framework Compliance	This risk highlights the bank's inability to comply with NIST CSF guidelines of timely incident response and recovery.
Remediation	Implement automated fraud detection systems. Integrate a real-time flagging and notification system in the event of anomalous behaviour.

Finding R-10: Mobile App AI Bias (Medium Risk)

Description	Stirling Bank's mobile banking application's AI system is susceptible to bias, due to non-representative training data. This may lead to perpetration of stereotypes towards certain groups of customers, impacting relations between the bank and its clients.
Risk Scenario	The biased AI model may flag transactions related to a certain demographic of people as potentially fraudulent. This can result in terminating transactions for those customers, negatively impacting the bank's reputation. It can also lead to false positives and lead to unnecessary investigations.
Impact Level	4
Business Impact	This primarily leads to damage to the bank's reputation due to customer dissatisfaction. There is also a risk for legal consequences as the AI may perpetrate human stereotypes and misbehave with customers.
Framework Compliance	This risk shows a lack of compliance with the NIST AI Risk Management Framework, which highlights the need for ethical AI usage.
Remediation	Audit AI fairness regularly and use more diversified training data. Apply ethical constraints to AI decision-making.

Finding R-11: AI Over-Dependence & Insufficient Explainability (Medium Risk)

Description	Employees at Sterling Bank rely heavily on AI decision-making without sufficient explainability for actions and decisions. AI decisions tend to be black-box and not entirely clear in its justification. Thus, there is limited justification for actions and thus a lack of governance of automated processes.
Risk Scenario	An employee may use the internal AI chatbot system to make a decision related to a customer. This can lead to the AI making an inappropriate decision for that customer's scenario, which the employee blindly executes without proper validation.
Impact Level	3
Business Impact	This poses significant decision risk as a lack of human oversight over AI decision-making can lead to harmful, unjustified actions without sufficient reasoning. It may be particularly challenging for Stirling Bank if under regulatory scrutiny and asked to explain actions taken.
Framework Compliance	This risk shows a lack of compliance with the NIST AI Risk Management Framework, which highlights the need for human oversight and accountability of decision-making.
Remediation	Enforce a GRC model where human oversight is mandatory over AI decision-making and proper justification is given before performing major actions.

Finding R-12: Inconsistent Security Logging (Low Risk)

Description	Logs for system activity and transactional activity is inconsistent, leading to gaps in understanding events. This makes post-incident forensics particularly difficult, leading to potential delays and misjudgement.
Risk Scenario	After a security breach, incomplete logs result in a lack of information on the event. This can make it difficult for fraud and forensics teams to make accurate decisions and investigate. This could lead to delays in response and
	recovery as the teams aim to acquire data on the security breach from elsewhere.
Impact Level	2
Business Impact	Insufficient logging can lead to delayed, insufficient and/or inaccurate response to a security breach. This could potentially lead to reputational damage.
Framework Compliance	This risk highlights the bank's misalignment with the NIST CSF, which indicates the importance of monitoring and event logging.
Remediation	Ensure regularly logging security events in accordance with GDPR regulations and following a policy of minimisation where possible.

Finding R-13: Inconsistent Security Logging (Low Risk)

Description	Stirling Bank does not provide regular security awareness programs for its employees. This can limit staff understanding of common cybersecurity threats and security practices. This can lead to social engineering persisting as a risk to the security posture of Stirling Bank.
Risk Scenario	An employee not well-informed on good email security practices may become victim to a phishing attack, resulting in their credentials becoming compromised. This can lead to an attacker penetrating security defences through impersonation.
Impact Level	2
Business Impact	Successful social engineering attacks can lead to system compromise and potential operational disruption.
Framework Compliance	This risk highlights the bank's misalignment with the NIST CSF and ISO 27001 Frameworks, which indicate the importance of training and awareness of cyber threats.
Remediation	Ensure periodic, mandatory security awareness programs are in place for all employees.

AI Risk & Ethics

AI is crucial for helping improve work efficiency and customer service for Stirling Bank. However, it is important to be aware of AI security risks.

AI training data can lead to the AI inheriting and perpetuating human stereotypes or producing unfair decisions, which employees may take away and execute. This can lead to organisation-wide inaccurate decision-making which can result in loss of reputability with customers and potential legal consequences.

AI overreliance can impair employee human judgement and result in blind trust in AI decision-making, which can be flawed, without validation. Under regulatory scrutiny, Stirling Bank may face legal consequences as a result of being unable to justify and explain AI decisions. It is important to make employees aware of the importance of human oversight and validation of AI decision-making processes.

Conclusion

Overall, Stirling Bank is at a Moderate to High risk level for a lack of appropriate GRC practices.

The GRC team recommends adopting a revised GRC model, improved through iterative development, taking guidance from the frameworks specified to boost credibility and security.

The GRC team also recommends making a shift from occasional audits to regular, automated compliance checks through real-time risk scoring and real-time policy adherence tracking.

- END OF REPORT -